



Architecture Diagram NEMU IPB

Perancangan dan Implementasi Protokol Keamanan Informasi pada Sistem NEMU IPB

Kelompok 7

Salma Putri Hanifah	G6401231010
Marsya Hasna Khairunnisa	G6401231015
Lathiifa Zahira Yahya	G6401231154

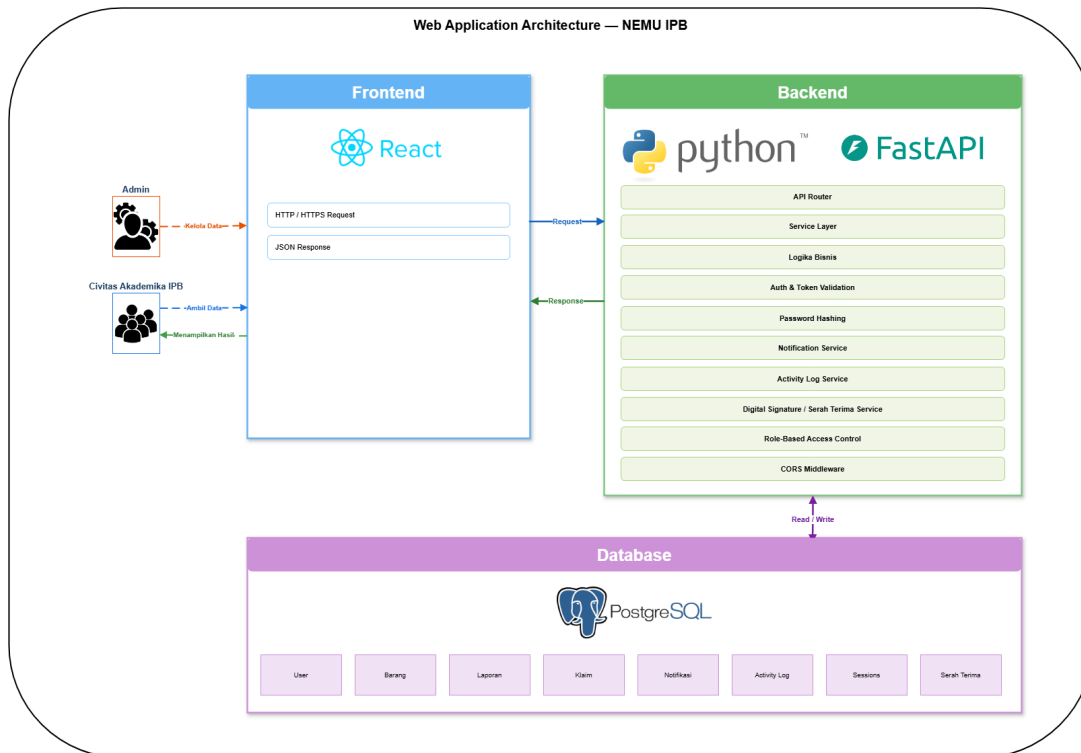
1. Gambaran Umum Arsitektur

NEMU IPB adalah aplikasi web lost and found untuk civitas akademika IPB. Aktor utama sistem adalah Civitas Akademika IPB sebagai pelapor, penemu, atau pengklaim barang, serta Admin sebagai pihak yang melakukan verifikasi laporan, klaim, dropoff, dan pemantauan aktivitas.

Arsitektur sistem terdiri dari Frontend React, Backend FastAPI, dan Database PostgreSQL. Frontend menjadi antarmuka pengguna, Backend FastAPI menjadi pusat pemrosesan request, validasi keamanan, dan logika bisnis, sedangkan PostgreSQL menyimpan data utama sistem seperti user, barang, laporan, klaim, notifikasi, dokumen serah terima, digital signature, dan activity log.

Backend menggunakan struktur router dan service layer. API router menerima request dari frontend, service layer menjalankan proses aplikasi, dan business logic mengatur aturan seperti autentikasi, validasi token, otorisasi role, validasi laporan, verifikasi klaim/dropoff, pembuatan notifikasi, pencatatan activity log, serta pembuatan dokumen serah terima dengan hashing dan digital signature. Alembic digunakan untuk migration schema database agar struktur tabel antar environment tetap konsisten.

2. Diagram Konseptual



3. Protokol Komunikasi

Frontend React mengirim request HTTP/HTTPS ke Backend FastAPI dan menerima response dalam format JSON. Pada konfigurasi lokal, frontend dapat menggunakan base URL `http://127.0.0.1:8000`. Pada production, seluruh komunikasi frontend ke backend harus menggunakan `https://` untuk melindungi token, data user, laporan, klaim, dan status barang selama transmisi.

Frontend production yang berjalan melalui HTTPS tidak boleh memanggil backend HTTP karena dapat menimbulkan mixed content dan kegagalan request di browser. Konfigurasi frontend menggunakan `REACT_APP_API_BASE_URL` sebagai base URL API dan menormalisasi trailing slash. Request production sebaiknya langsung mengarah ke endpoint HTTPS final agar tidak bergantung pada redirect yang tidak perlu.

Endpoint tertentu membutuhkan token bearer yang dihasilkan saat login. Backend melakukan validasi token untuk memastikan hanya user terautentikasi yang dapat mengakses fitur tertentu. Role admin dan civitas digunakan untuk authorization, terutama pada endpoint admin seperti verifikasi laporan, verifikasi klaim/dropoff, dashboard admin, dan activity log. Jika token tidak valid atau expired, akses harus ditolak.

Backend FastAPI menggunakan CORS middleware. Di kode terdapat daftar origin valid seperti `https://nemuiipb.vercel.app`, `http://localhost:3000`, dan `http://127.0.0.1:3000`, tetapi konfigurasi middleware saat ini masih memakai wildcard `allow_origins=["*"]`. CORS adalah kontrol tambahan di sisi browser dan bukan pengganti authentication, token validation, atau role-based

access control.

4. Protokol AAA

Komponen AAA	Penerapan pada NEMU IPB
Authentication	User login menggunakan username/email IPB dan password. Backend memvalidasi password terhadap password_hash menggunakan bcrypt, lalu membuat access token.
Authorization	Backend membatasi akses berdasarkan role admin atau civitas. Endpoint admin melakukan pemeriksaan role sebelum menjalankan proses verifikasi atau akses data admin.
Accounting	Aktivitas penting, terutama aksi admin seperti approve/reject laporan dan verifikasi pickup/dropoff, dicatat melalui activity_logs.

5. Manajemen Kunci dan Hashing

Password tidak disimpan dalam bentuk plaintext, tetapi disimpan sebagai password_hash. Kode backend menggunakan bcrypt melalui passlib untuk memverifikasi password saat login. Dokumen serah terima menggunakan dokumen_hash berbasis SHA-256 untuk menjaga integritas isi dokumen. Digital signature dibuat dari hash dokumen menggunakan pasangan kunci RSA, lalu public key disimpan untuk proses verifikasi signature. Dengan mekanisme ini, perubahan isi dokumen dapat dideteksi dan proses serah terima memiliki dukungan non-repudiation.

Backend menggunakan environment variable untuk konfigurasi sensitif, antara lain DATABASE_URL, SECRET_KEY, FERNET_KEY, ALGORITHM, dan ACCESS_TOKEN_EXPIRE_MINUTES. SECRET_KEY digunakan untuk JWT/token, sedangkan FERNET_KEY digunakan oleh encryption service untuk mengenkripsi field sensitif seperti dokumen serah terima dan signature. Frontend menggunakan REACT_APP_API_BASE_URL untuk menentukan URL backend. Secret tidak boleh di-commit ke repository.

6. Alur Data Aman

1. **Login:** user mengirim username dan password dari frontend. Backend mencari user, memverifikasi password hash, lalu mengembalikan access token jika valid.
2. **Membuat laporan kehilangan/penemuan:** civitas mengirim data laporan melalui endpoint protected. Backend memvalidasi token, memvalidasi input, membuat data barang dan laporan di PostgreSQL.

3. **Admin menyetujui/menolak laporan:** admin mengakses endpoint admin dengan token valid. Backend memeriksa role admin, memperbarui status laporan, membuat notifikasi, dan mencatat activity log.
4. **Klaim barang:** civitas mengajukan klaim menggunakan laporan kehilangan miliknya. Backend memvalidasi kepemilikan laporan, status barang, dan aturan klaim.
5. **Dropoff barang:** untuk laporan penemuan yang disetujui, sistem menghasilkan kode dropoff yang dikirim melalui notifikasi. Admin memverifikasi kode saat barang diserahkan.
6. **Verifikasi klaim/dropoff oleh admin:** admin memverifikasi klaim atau kode pickup/dropoff. Backend memperbarui status barang/laporan/klaim, membuat notifikasi, dan mencatat activity log.
7. **Serah terima dan digital signature:** saat klaim diterima, sistem membuat dokumen serah terima, menghitung dokumen_hash, membuat digital_signature, dan menyimpan public key untuk verifikasi.
8. **Notifikasi dan activity log:** perubahan status penting menghasilkan notifikasi kepada user terkait dan pencatatan aktivitas untuk kebutuhan audit.

7. Aset Informasi yang Dilindungi

Aset	Lokasi penyimpanan	Risiko keamanan	Mekanisme perlindungan
Data user	Tabel users PostgreSQL	Kebocoran identitas, perubahan akun tidak sah	Token validation, role authorization, akses database terbatas
Password hash	Kolom users.password_hash	Brute force, kebocoran hash	Bcrypt password hashing, tidak menyimpan plaintext
Token/session	Token JWT di frontend; migration juga menyiapkan tabel sessions	Token dicuri atau digunakan ulang	Bearer token validation, expiry token, HTTPS wajib untuk production
Data laporan	Tabel laporan dan barang	Manipulasi status atau isi laporan	Protected endpoint, validasi input, role admin untuk verifikasi
Data barang	Tabel barang	Status barang diubah tidak sah	Endpoint admin untuk update status, audit log

Data klaim	Tabel klaim_barang	Klaim palsu atau klaim milik user lain	Validasi kepemilikan laporan kehilangan, aturan klaim di service layer
Dokumen serah terima	Tabel serah_terima	Dokumen dibaca atau diubah tidak sah	Enkripsi field sensitif, access control admin
Dokumen hash	Kolom dokumen_hash	Hash diganti untuk menutupi manipulasi	Recalculate hash saat verifikasi, akses database terbatas
Digital signature	Kolom digital_signature	Signature dipalsukan atau dimodifikasi	RSA signature, public key verification, enkripsi signature di database
Activity log	Tabel activity_logs	Audit trail hilang atau diubah	Pencatatan aksi penting, akses log dibatasi admin

8. Ancaman Keamanan Utama

- **Unauthorized access:** user tidak sah mengakses endpoint protected.
- **Token/session misuse:** token dicuri, digunakan ulang, atau disimpan tidak aman di browser.
- **Password leakage:** password plaintext bocor dari input, log, atau database.
- **Manipulasi laporan/klaim:** user mengubah status laporan atau mengklaim barang tanpa hak.
- **Manipulasi dokumen serah terima:** isi dokumen diubah setelah proses serah terima.
- **Admin abuse:** admin menyalahgunakan hak akses untuk mengubah status atau data.
- **Data tampering:** perubahan data langsung di database tanpa proses aplikasi.
- **Broken access control:** endpoint admin atau data user dapat diakses role yang salah.
- **SQL injection:** input berbahaya mencoba mempengaruhi query database.
- **Kehilangan audit trail:** aktivitas penting tidak tercatat sehingga insiden sulit ditelusuri.
- **Schema tidak sinkron:** perbedaan migration/model antar environment dapat mengganggu authentication/session, klaim, notifikasi, dan audit log.

9. Kontrol Keamanan

Kontrol keamanan	Tujuan	Komponen terkait	Status
------------------	--------	------------------	--------

Password hashing	Melindungi password dari penyimpanan plaintext	utils/security.py, tabel users	Diterapkan
Token/session validation	Memastikan endpoint protected hanya diakses user valid	JWT bearer token, get_current_user	Diterapkan
Role-based access control	Membatasi fitur admin dari civitas	ensure_admin, router admin/klaim	Diterapkan
Input validation	Menolak input kosong, tanggal masa depan, dan format dokumentasi tidak valid	Pydantic schema LaporanCreate	Diterapkan sebagian
Activity log	Mencatat aksi penting untuk audit	activity_logs, admin_activity_service	Diterapkan
Digital signature	Menjamin integritas dan non-repudiation dokumen	signature_service, serah_terima_service	Diterapkan
Document hashing	Mendeteksi perubahan dokumen serah terima	SHA-256 dokumen_hash	Diterapkan
HTTPS saat deployment	Melindungi kredensial, token, data user, laporan, klaim, dan status barang saat transmisi	Frontend, backend, reverse proxy/platform hosting	Direkomendasikan/ wajib untuk production

Mixed content prevention	Mencegah frontend HTTPS memanggil backend HTTP	REACT_APP_API_BASE_URL, konfigurasi deployment	Diterapkan sebagian, perlu dipastikan di production
CORS origin restriction	Membatasi origin browser yang boleh mengakses API	FastAPI CORS middleware	Diterapkan sebagian, wildcard perlu diperketat untuk production
Environment variable untuk secret	Melindungi SECRET_KEY, DATABASE_URL, FERNET_KEY, ALGORITHM, ACCESS_TOKEN_EXPIRE_MINUTES	Backend environment, frontend REACT_APP_API_BASE_URL	Diterapkan untuk konfigurasi utama, secret tidak boleh di-commit
Database migration dengan Alembic	Mengelola perubahan schema secara terkontrol	backend/database/migrations	Diterapkan
Konsistensi schema database	Menjaga tabel users, sessions, barang, laporan, klaim_barang, notifikasi, serah_terima, activity_logs, dan alembic_version selaras dengan kode	SQLAlchemy models, Alembic migration	Diterapkan melalui migration, perlu dijaga antar environment
Backup database	Mencegah kehilangan data dan audit trail	PostgreSQL	Direkomendasikan

Error handling tanpa detail sensitif	Mencegah kebocoran stack trace atau detail internal	FastAPI router/service	Direkomendasikan
Rate limiting login	Mengurangi brute force credential	Endpoint /auth/login	Direkomendasikan